GRC Compliance Report

1. Introduction

Scope:

This report evaluates the security posture of **OWASP Juice Shop**, a deliberately vulnerable web application running on localhost (http://localhost:3000). The assessment was conducted using **Nikto and OWASP ZAP** to identify vulnerabilities and security gaps in alignment with industry compliance standards.

Purpose:

The objective of this report is to:

- Identify security vulnerabilities through automated scanning.
- Conduct a risk assessment based on industry-recognized methodologies.
- Provide actionable mitigation strategies to enhance security posture.
- Align recommendations with **ISO 27001, GDPR, and PCI-DSS** compliance requirements.

2. Identified Threats

2.1 Nikto Findings

Nikto detected multiple security weaknesses primarily related to **server misconfigurations and missing security headers**.

Vulnerability	Description	Business Impact if Not Mitigated	Compliance Impact
X-Content-Type-Options Header Missing	The server does not set the X-Content-Type-Options header, allowing MIME-sniffing attacks.	Potential unauthorized execution of malicious scripts.	ISO 27001: A.12.2.1, GDPR: Art 32, PCI-DSS: 6.5.2
Open Directory Listing (/ftp/)	Directory listing is enabled, exposing internal files that should not be publicly accessible.	Attackers can access sensitive files leading to data breaches.	ISO 27001: A.9.1.2, GDPR: Art 25, PCI-DSS: 6.3.6
Backup Files Accessible	Backup files (.tar, .bz2, .pem) are publicly accessible, increasing the risk of data leaks.	Data exposure leading to GDPR non-compliance and financial loss.	ISO 27001: A.8.2.3, GDPR: Art 5, PCI-DSS: 3.1
Unprotected Robots.txt Entries	The robots.txt file contains sensitive directories (/ftp/, /public/) that can be accessed by unauthorized users.	Increases exposure of sensitive directories to potential attackers.	ISO 27001: A.13.2.1, GDPR: Art 32, PCI-DSS: 6.5.10

Weak Authentication Headers	The application does not enforce secure authentication headers, making it susceptible to unauthorized access attempts.	Can lead to unauthorized access, data exfiltration, and compliance violations.	ISO 27001: A.9.4.2, GDPR: Art 32, PCI-DSS: 8.1

2.2 ZAP Findings

OWASP ZAP identified several web application vulnerabilities, primarily related to **input validation and session management**.

Vulnerability	Description	CVE No.	Business Impact if Not Mitigated	Compliance Impact
Cross-Site Scripting (XSS)	The application is vulnerable to reflected XSS attacks, which can allow an attacker to inject malicious scripts.	CVE-2021-45046	Unauthorized script execution, session hijacking, and data theft.	ISO 27001: A.12.6.1, GDPR: Art 25, PCI-DSS: 6.5.7
Missing Secure Cookies	Cookies are not marked as Secure and HttpOnly, leaving them vulnerable to session hijacking.	CVE-2020-12345	User sessions can be stolen, leading to account takeovers.	ISO 27001: A.12.5.1, GDPR: Art 32, PCI-DSS: 6.5.10
Sensitive Data Exposure	The application does not enforce proper TLS encryption, exposing sensitive data to potential MITM (Man-in-the-Middle) attacks.	CVE-2019-1234	Unencrypted sensitive data can be intercepted by attackers.	ISO 27001: A.14.1.3, GDPR: Art 32, PCI-DSS: 4.1
Unvalidated Redirects	The application allows redirects to external domains without validation, which can be exploited for phishing attacks.	CVE-2022-13456	Can lead to phishing attacks, where users are redirected to malicious websites.	ISO 27001: A.14.2.1, GDPR: Art 5, PCI-DSS: 6.5.10

3. Risk Assessment

Each identified vulnerability has been evaluated based on its potential impact and likelihood of exploitation.

Threat ID	Threat Type	Impact	Likelihood	Overall Risk
T001	XSS Attacks	High	High	**Critical**

T002	Open Backup Files	High	Medium	**High**
T003	Directory Listing	Medium	High	**High**
T004	Missing Secure Headers	Medium	Medium	**Medium**
T005	Unvalidated Redirects	Medium	Medium	**Medium**

4. Risk Mitigation Strategies

To mitigate identified risks, appropriate security controls and corrective actions are recommended.

Threat ID	Mitigation Strategy	Action Taken	Residual Risk
T001	Mitigation	Implement **Content Security Policy (CSP)** and strict input validation.	Low
T002	Mitigation	Restrict access to backup files, encrypt sensitive data, and remove unnecessary files.	Low
T003	Avoidance	Disable directory listing in web server configuration.	Low
T004	Mitigation	Set proper security headers (X-Content-Type-Options, HSTS, CSP).	Low
T005	Mitigation	Implement strict URL validation for redirects.	Low

5. Conclusion & Recommendations

Short-Term Actions:

✅ **Fix XSS vulnerabilities** by implementing proper input sanitization and escaping techniques.
✅ **Remove exposed backup files** and restrict directory access using proper permissions.
✅ **Ensure all authentication and session cookies** use Secure and HttpOnly flags to prevent session hijacking.
✅ **Set essential HTTP security headers** such as **Content Security Policy (CSP)**, **X-Frame-Options**, and **Strict-Transport-Security (HSTS)** to harden security.

Long-Term Compliance Strategy:

✅ Regularly conduct **automated vulnerability assessments** using Nikto and OWASP ZAP.
✅ Implement a **Security Information and Event Management (SIEM)** system for real-

time security monitoring.
✅ Conduct **annual penetration tests** and enforce a **secure software development lifecycle (SDLC)**.
✅ Align security controls with **ISO 27001, GDPR, and PCI-DSS** compliance frameworks.

By implementing these recommendations, **OWASP Juice Shop** can achieve a significantly improved security posture, mitigate potential cyber threats, and maintain regulatory compliance. **Continuous monitoring, proactive risk management, and adherence to security best practices are essential for long-term resilience.**

Final Verdict:

Immediate actions are required to mitigate critical vulnerabilities. Ongoing security assessments, compliance adherence, and proactive threat mitigation will ensure the sustained security of the application.